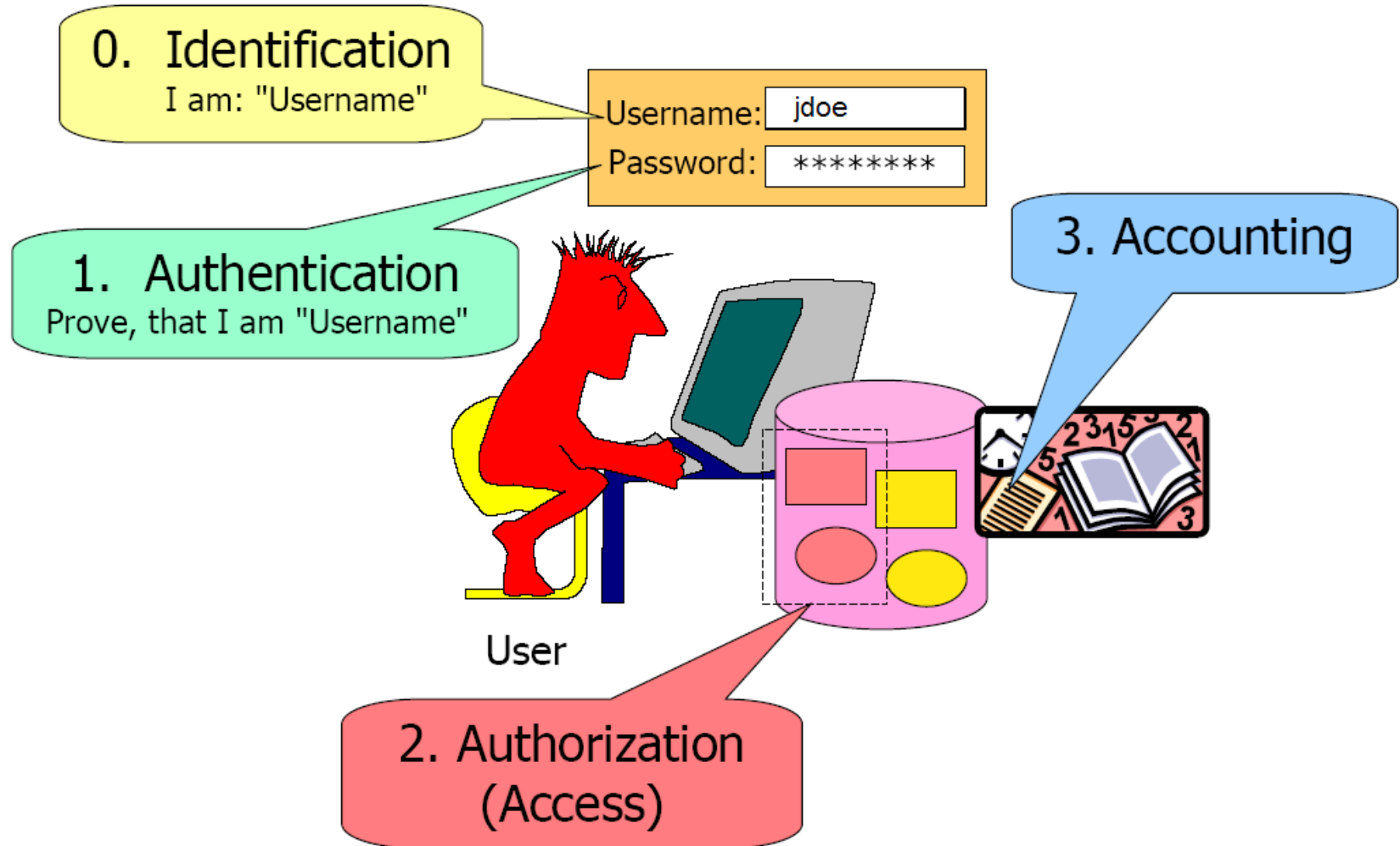


1. Protocoale de Autentificare



Authentication, Authorization, Accounting (AAA)



Autentificarea utilizatorilor

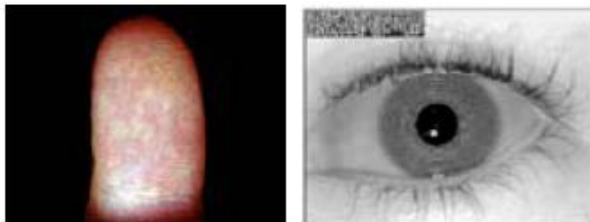
- Ceea ce utilizatorul cunoaște (parolă, PIN)

Username:
Password:

- Ceea ce utilizatorul deține (certificat digital, token)



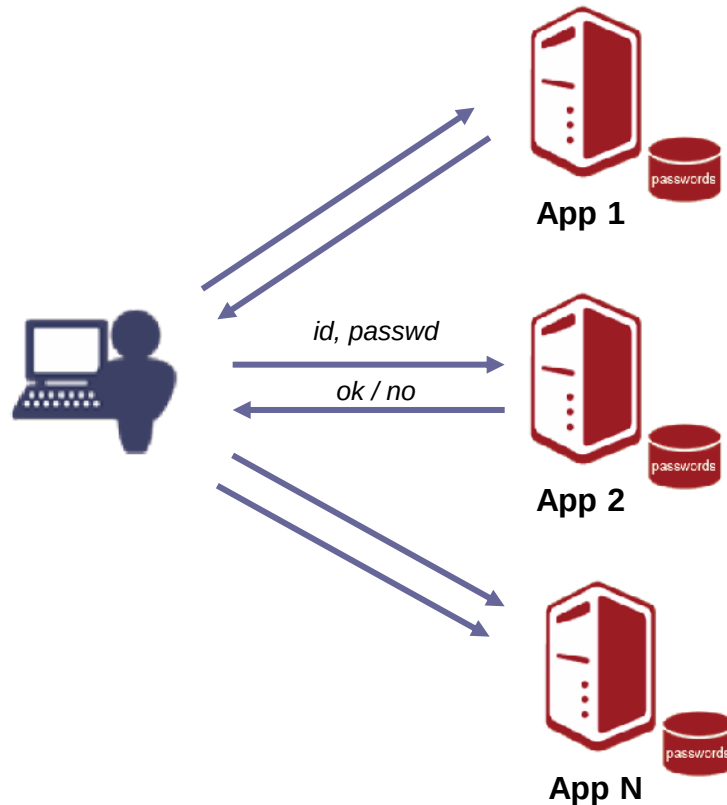
- Ceea ce utilizatorul este (amprenta, voce)



- Autentificarea sigură a utilizatorilor presupune combinarea a cel puțin doi factori!

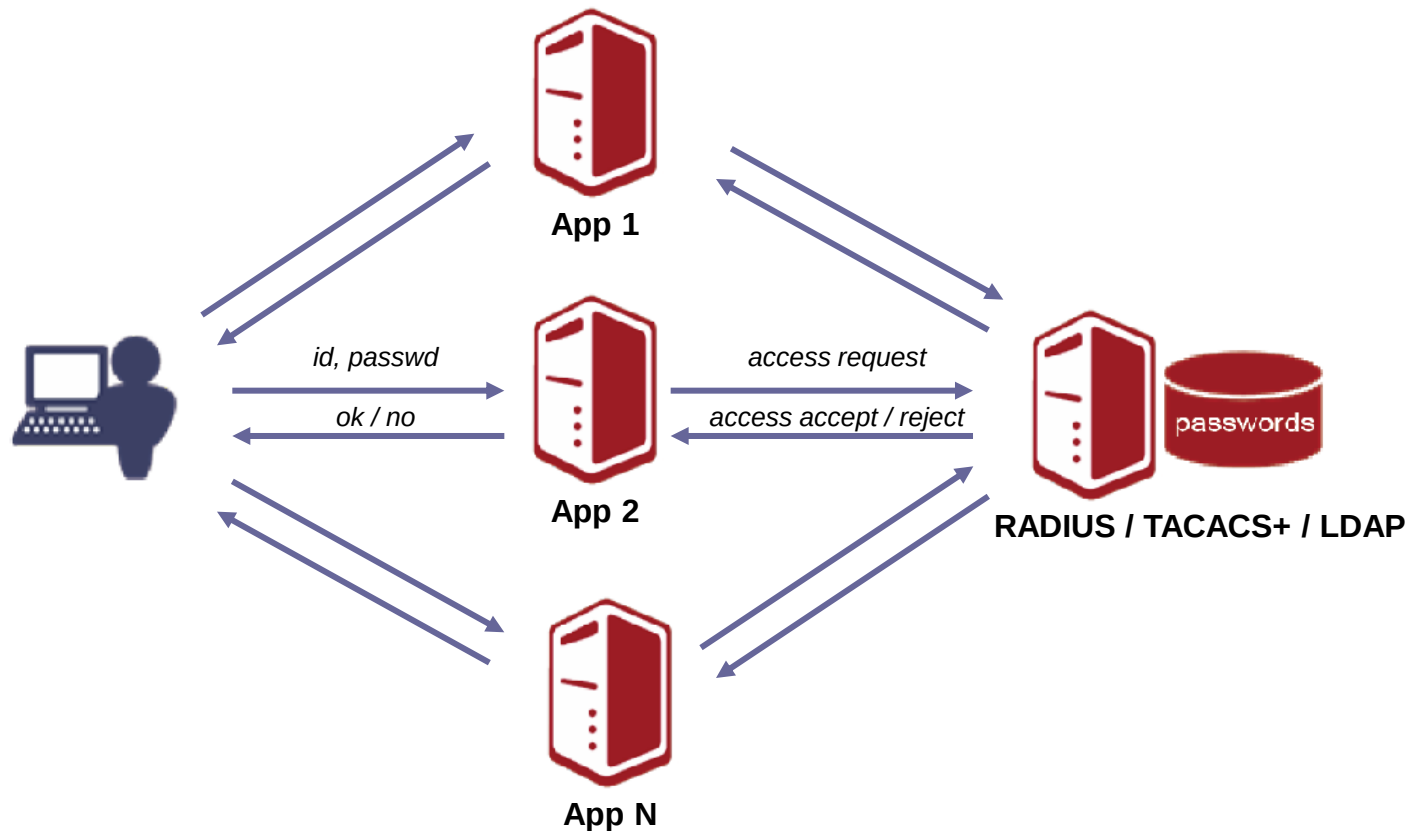
Autentificare directă

- Fiecare sistem are o bază de date proprie pentru autentificarea utilizatorilor
- Ok, pentru site-uri cu un număr mic de utilizatori / aplicații



Autentificare indirectă

- Bază de date centrală folosită în comun de mai multe sisteme
 - RADIUS, TACACS+, LDAP
- Management centralizat al utilizatorilor

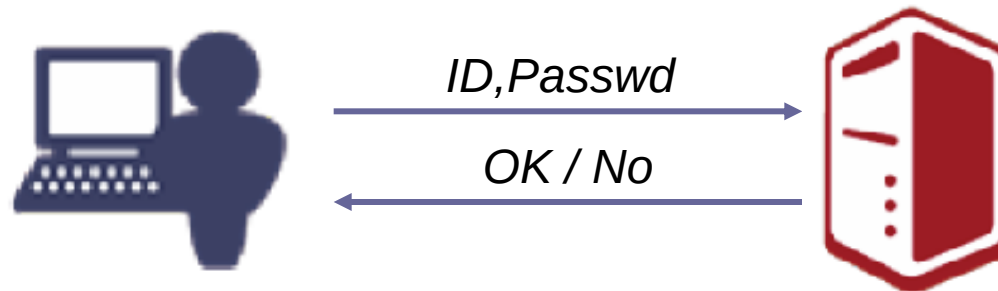


Protocole de autentificare

- Password Authentication Procedure (PAP)
- Challenge-Handshake Authentication Protocol (CHAP)
- Windows NT LAN Manager (NTLM)
- Kerberos
- Certificate digitale
- Generatoare de parole de unică folosință
- Biometrice

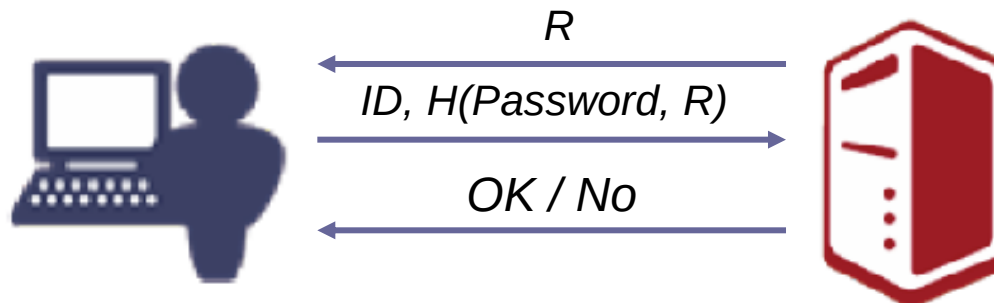
PAP

- Transmiterea în clar a username-ului și parolei
- IETF RFC 1334



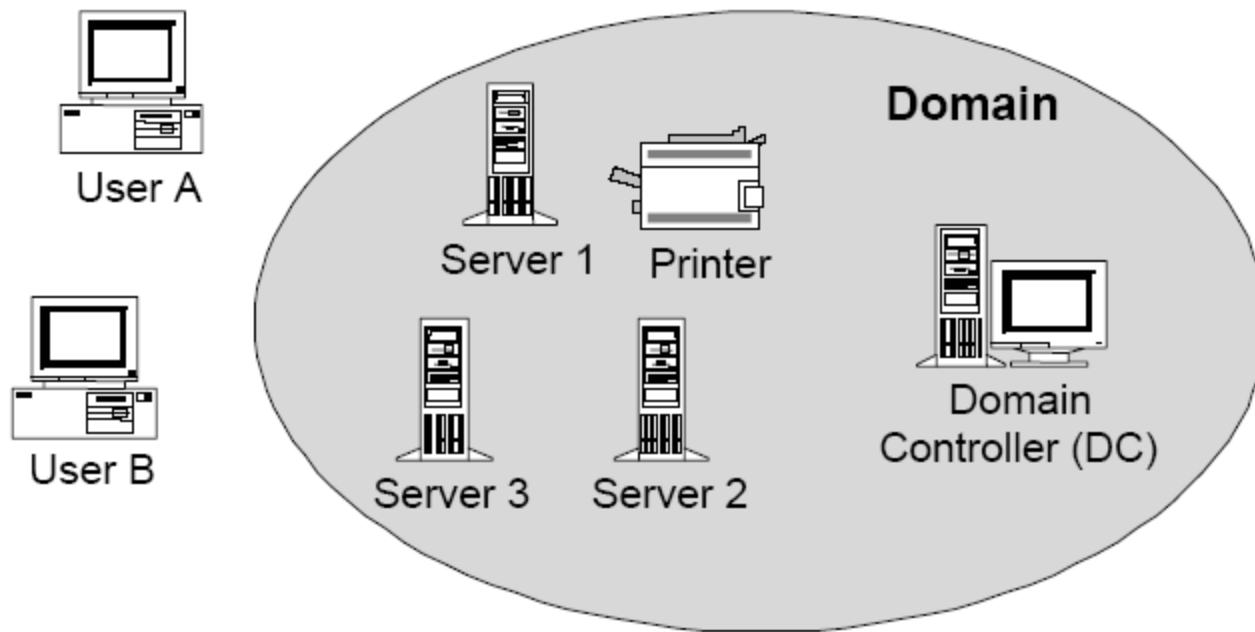
CHAP

- Protocol în trei pași:
 - Provocare (Challenge)
 - Răspuns
 - Succes / Failure
- Parola nu circulă niciodată în clar prin rețea
- Valoarea aleatoare (provocarea) trebuie să fie de fiecare dată alta pentru a evita atacurile prin reluare
- IETF RFC 1994

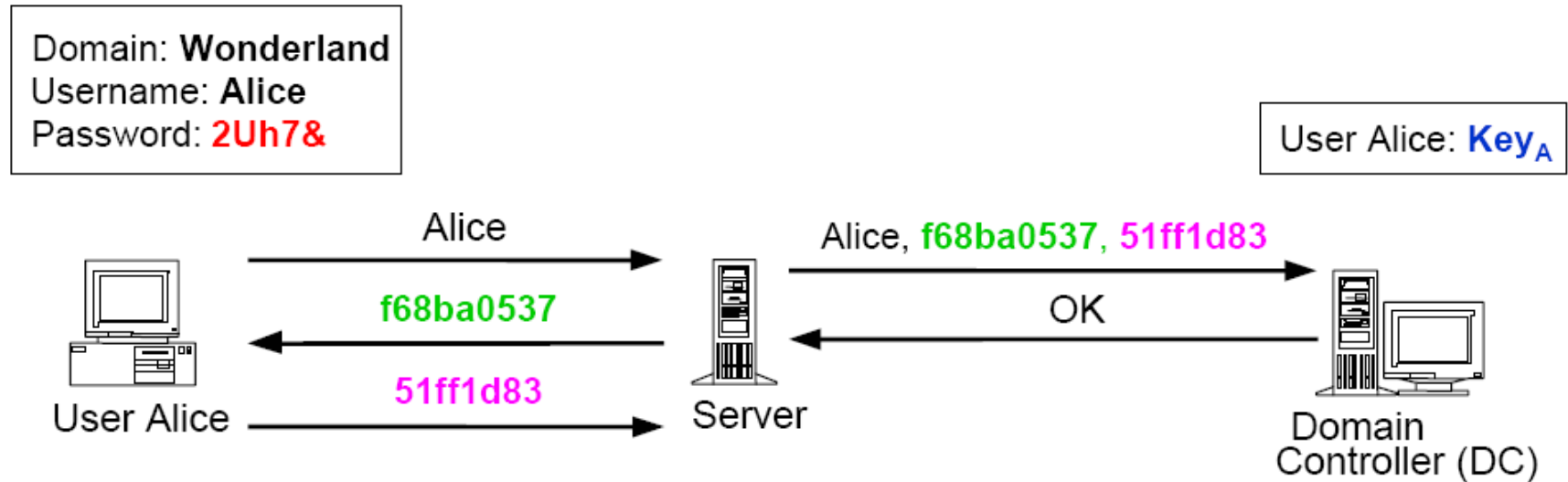


- **Autentificare în Domenii Windows**
- **Un domeniu este o colecție de servicii (E-mail, File Sharing, Printing, etc) administrate prin intermediul unui Domain Controller (DC)**
- **Administrare centralizată:**
 - Fiecare utilizator are un singur cont pentru un domeniu, gestionat de către Domain Controller (DC)
 - Nu este nevoie ca utilizatorii să aibă conturi pe fiecare server din domeniu
- **Flexibilitate ridicată:**
 - Administrare la nivel de grup
 - Domenii multiple (relații de încredere între domenii)
- **Toată lumea trebuie să aibă încredere în Domain Controller**

NTLM (cont.)



Protocolul NTLM



$H(2Uh7\&) = Key_A$
 $E(f68ba0537, Key_A) = 51ff1d83$

Challenge: **f68ba0537**

$E(f68ba0537, Key_A) = 51ff1d83$
Comparison with **51ff1d83** – ok?

H: Hash function
 $E(x, k)$: Encryption of **x** with key **k**

Securitatea NTLM

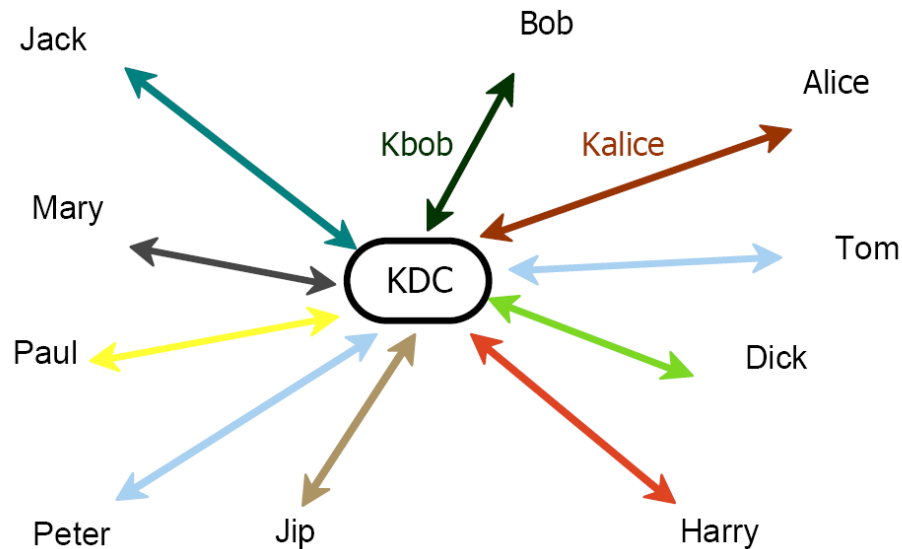
- **Avantaje:**
 - Parola utilizatorului nu este niciodată transmisă în clar
 - Parola utilizatorului este cunoscută numai de către DC
 - Protocol simplu și eficient dacă de folosesc parole sigure
- **Dezavantaje:**
 - Protocolul de autentificare trebuie repetat pentru fiecare server în parte
 - DC reprezintă un element critic (instalare Backup Domain Controller)
 - Parolele slabe sau scurte pot fi sparte offline prin atacuri de tip dicționar

Kerberos



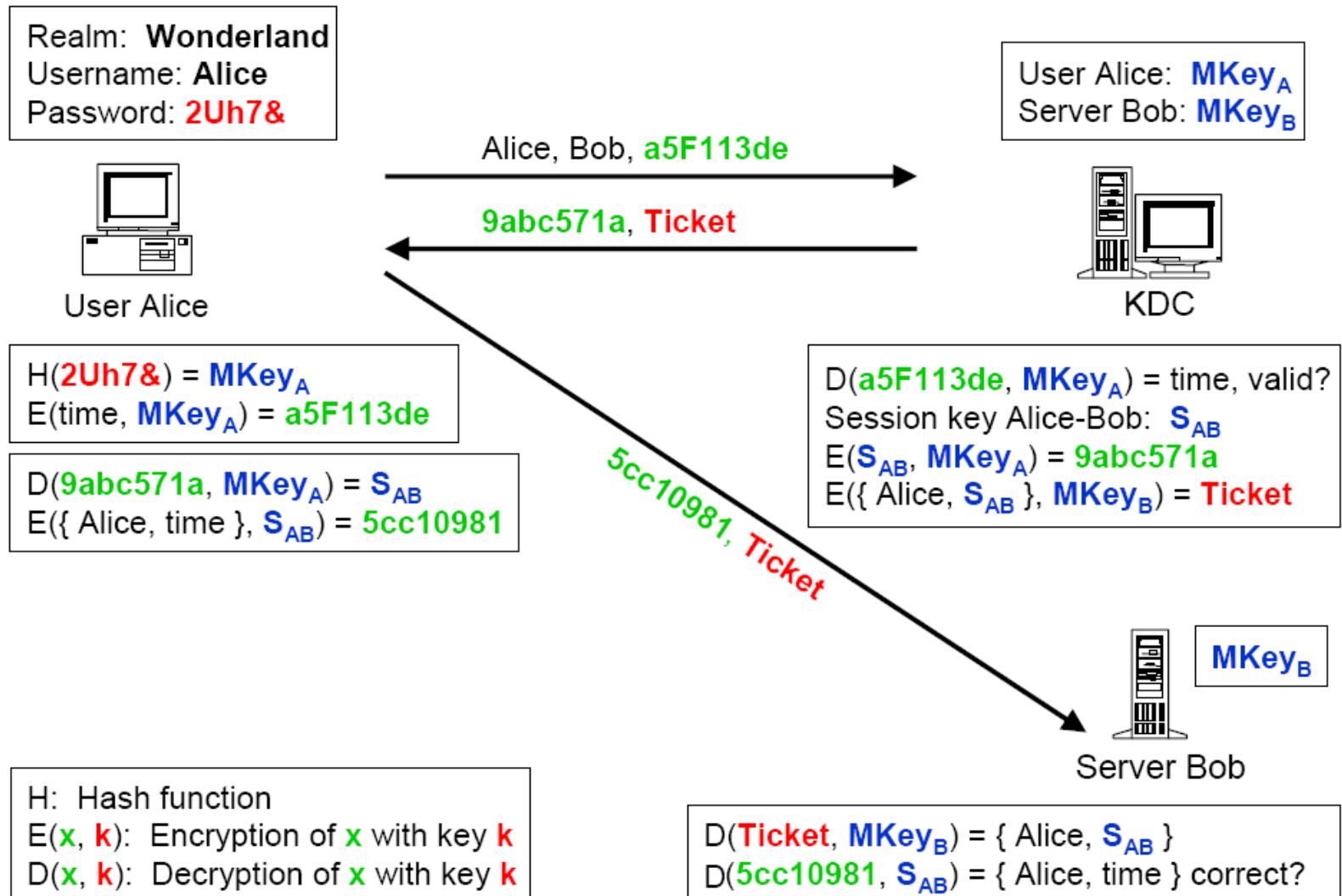
- Dezvoltat în 1983 în cadrul proiectului Athena de la Massachusetts of Technology (MIT)
 - <http://web.mit.edu/kerberos/www/>
- Autentificarea în rețele TCP/IP bazate pe sisteme Unix
- Algoritmi criptografici simetrici (DES)
- Se bazează pe serviciile de mediere oferite de un terț de încredere (KDC - Key Distribution Center)
- Derivat din schema Needham și Schroeder
- Autentificare mutuală între entități
- Versiunea curentă v5 (IETF RFC 1510, 1993).
- Microsoft a adoptat Kerberos începând cu Windows 2000
 - Windows folosește o versiune extinsă a protocolului Kerberos (suport pentru certificate digitale stocate pe smart carduri)

Kerberos KDC



- Key Distribution Center (KDC)
- Fiecare entitate (principal) are câte o cheie secretă master pe care o înregistrează la KDC
 - cheile master ale utilizatorilor sunt derivate din parola de login
- Fiecare acces securizat este “mediat” prin intermediul unor tickete Kerberos

Protocolul Kerberos Simplificat

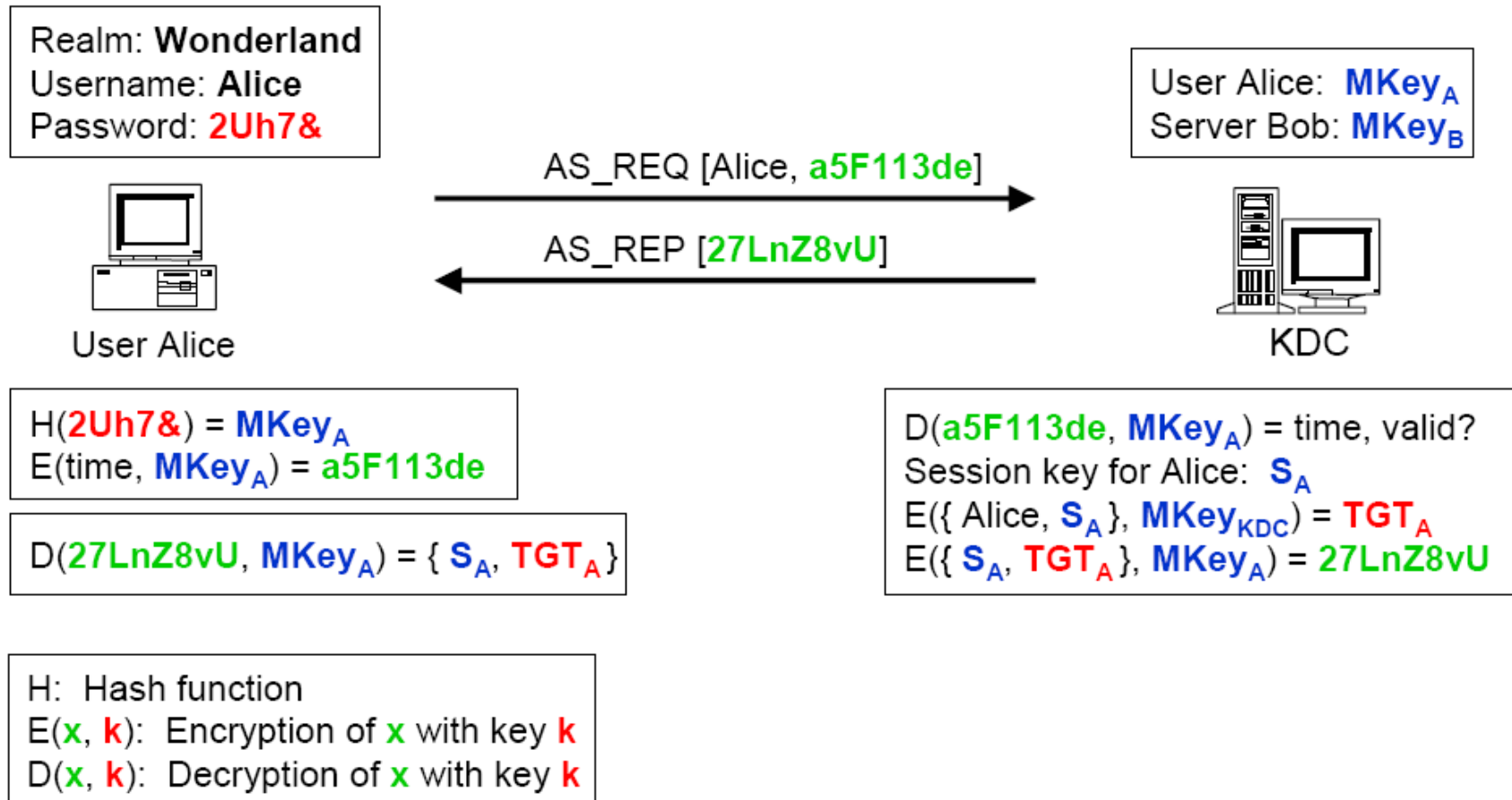


Protocolul Kerberos Simplificat (cont.)

- **Dezavantaje:**
 - cheia master a utilizatorului trebuie folosită de fiecare dată când se accesează un server și trebuie emis un nou ticket de către KDC
 - utilizatorul trebuie să introducă de fiecare dată parola atunci când se trimite o cerere de emitere ticket către KDC sau cheia master a utilizatorului trebuie ținută într-o memorie temporală (risc de securitate!)
- **Soluție:** emiterea unei chei de sesiune și a unui ticket special de către KDC (Ticket-Granting Ticket) având un timp de viață mai lung (8-24 ore)
 - utilizatorul trebuie să introducă mai rar parola

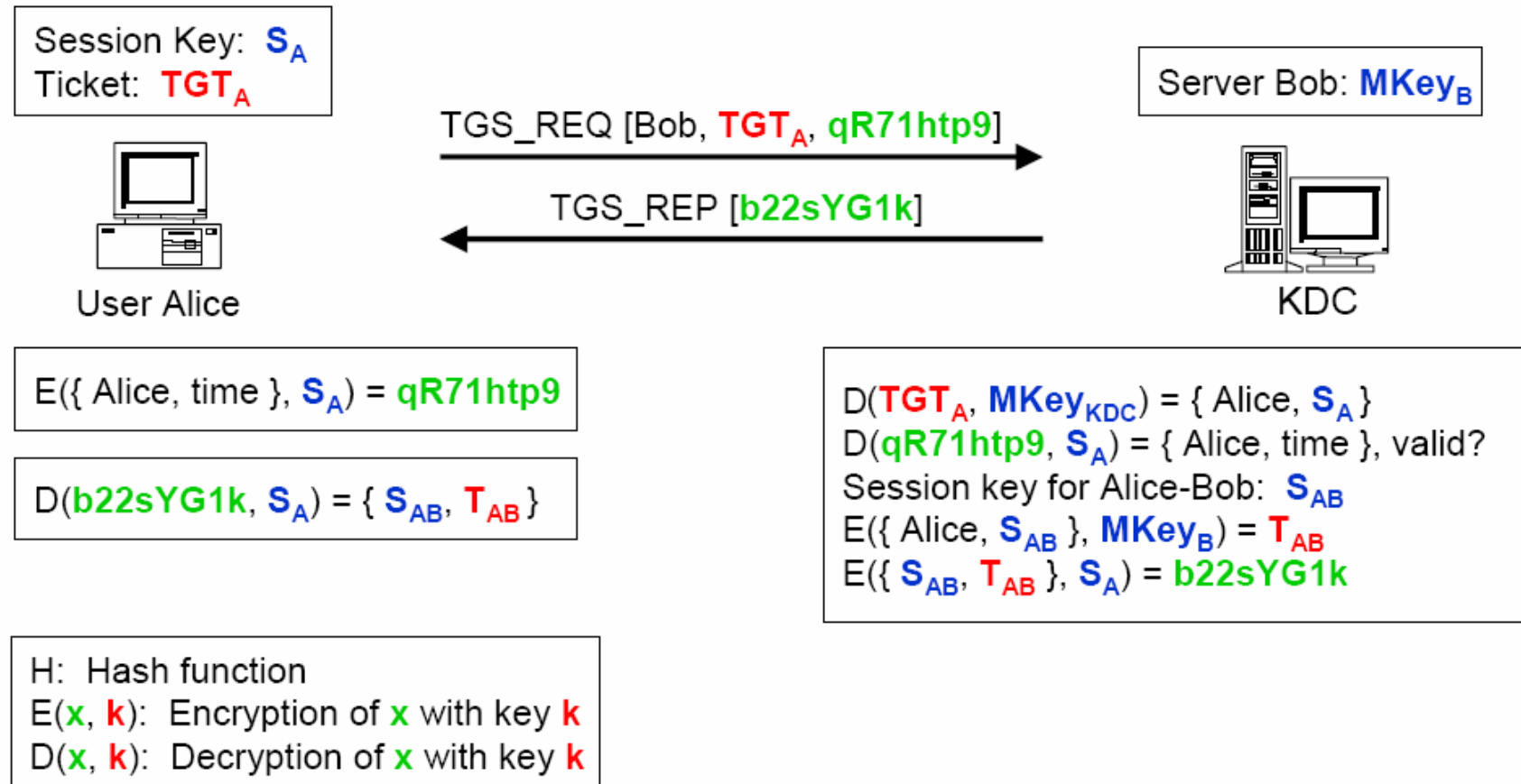
Protocolul Kerberos

Autentificarea Inițială



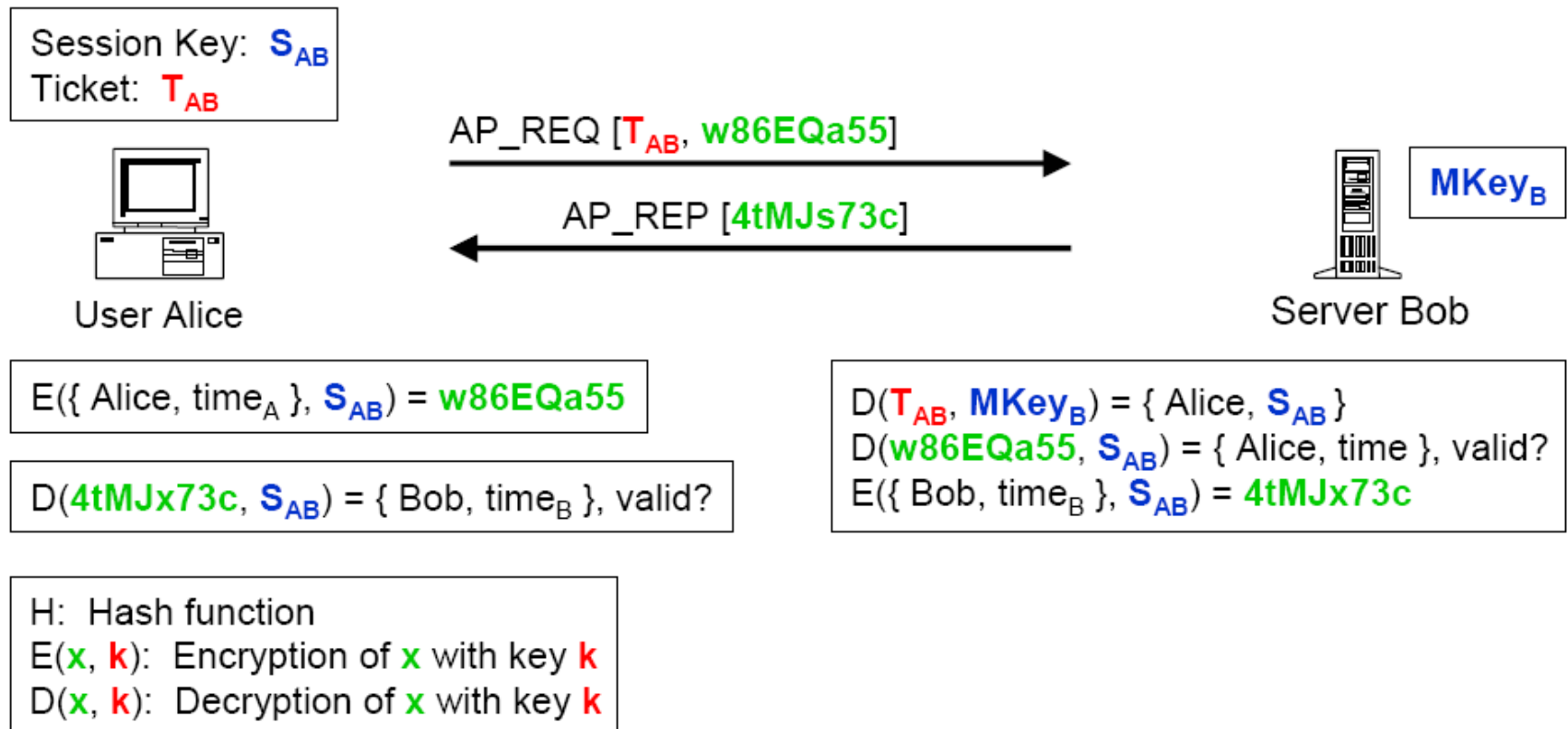
Protocolul Kerberos

Obținere Ticket de Acces



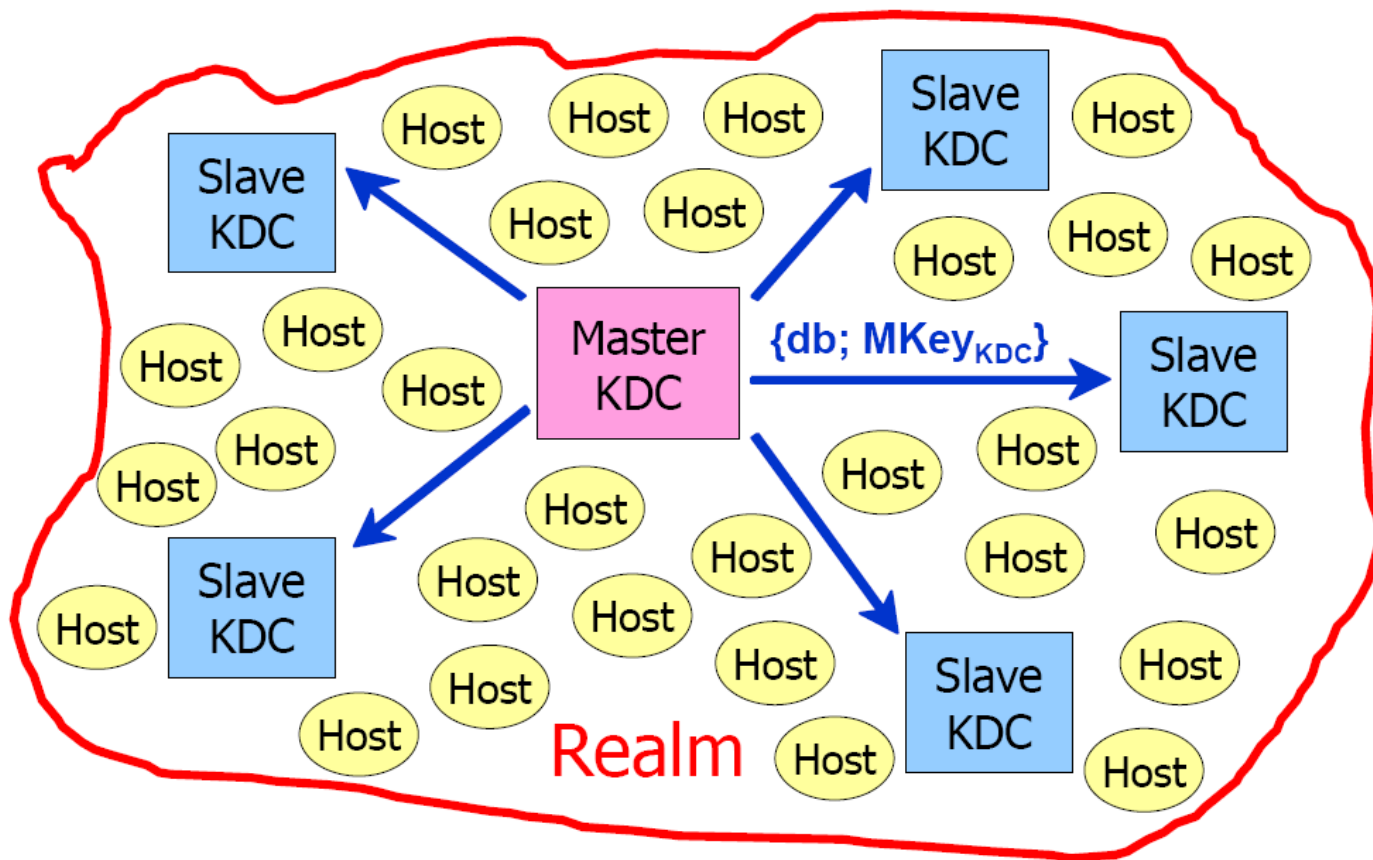
Protocolul Kerberos

Autentificarea Client / Server



Kerberos

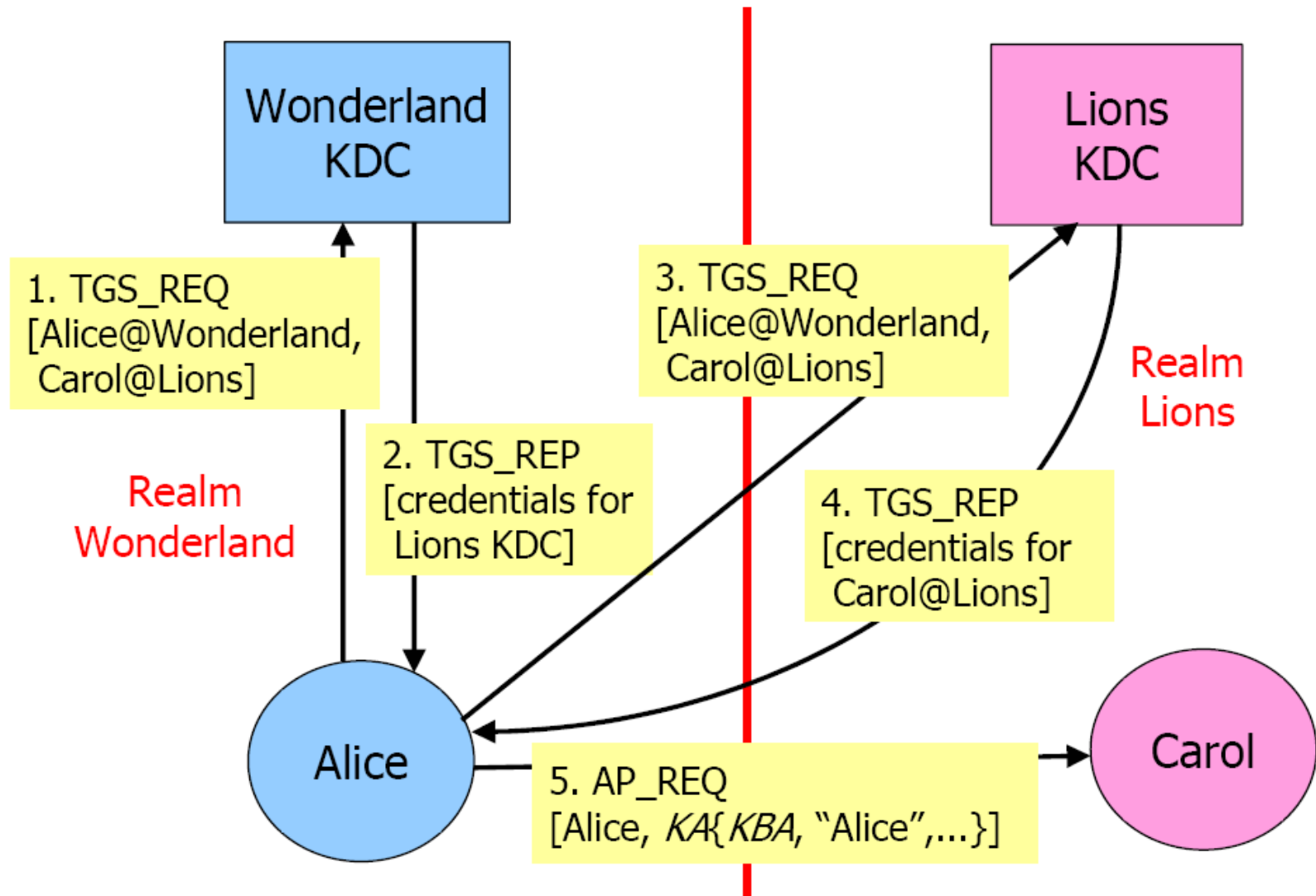
Replicarea KDC



- Baza de date a KDC Master este transferată periodic către KDC Slave
- Bazele de date ale KDC Slave sunt read-only

Kerberos

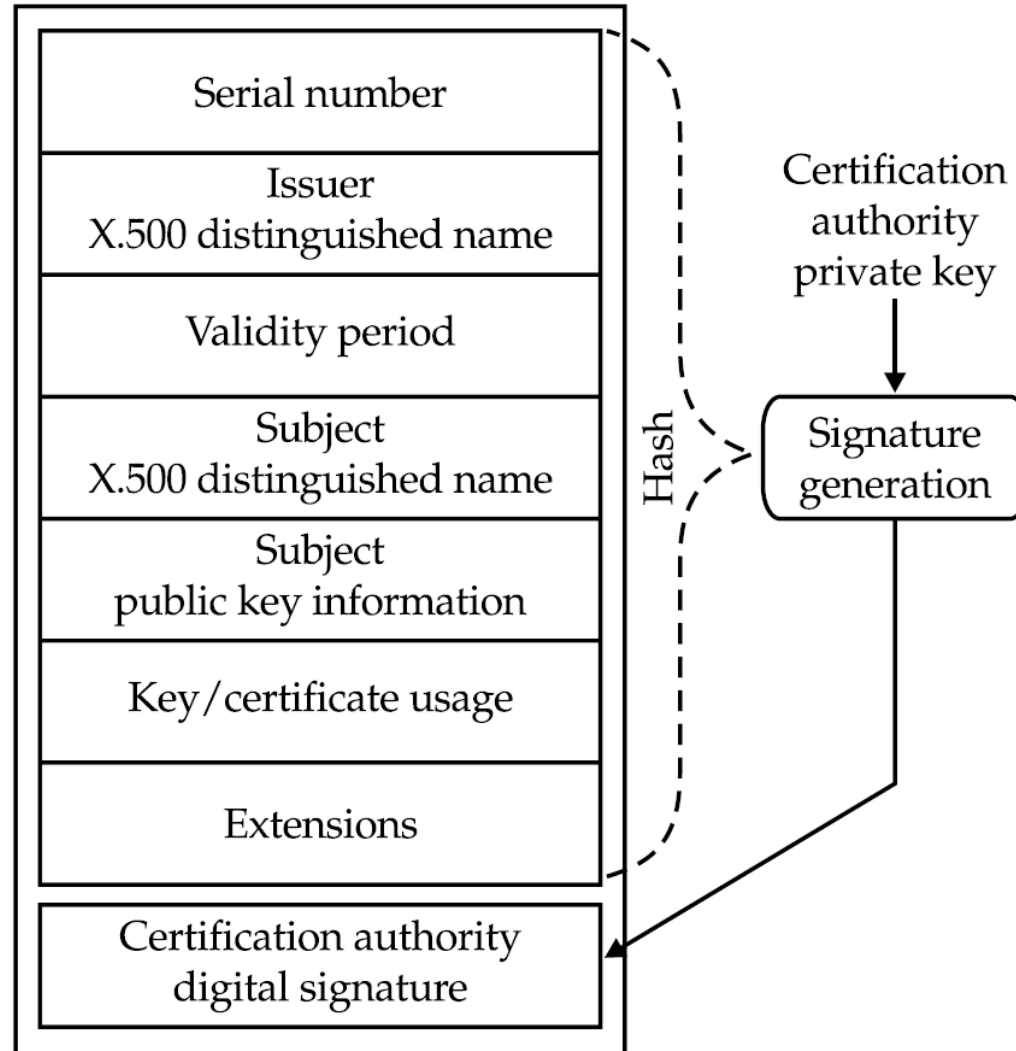
Autentificarea între realm-uri



Autentificarea cu Certificate Digitale

- **ITU-T Recommendation X.509: Information Technology – Open Systems Interconnection – The Directory: Authentication Framework**
- **Infrastructuri de Chei Publice (PKI)**
 - **Autoritate de Certificare (CA) = terț de încredere care garantează faptul că o cheie aparține unei entități**
 - **certificate digitale de chei publice**

Certificate digitale



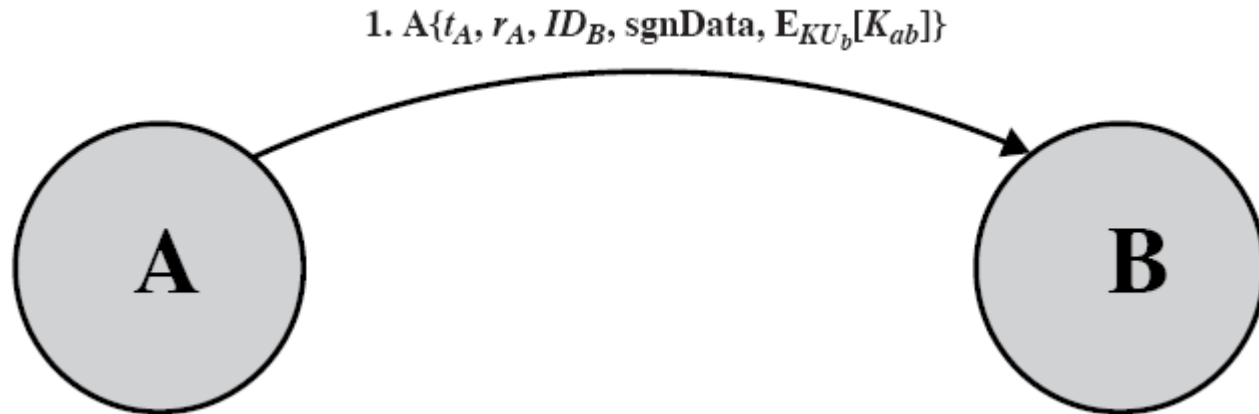
Certificate digitale (cont.)

- **Subject X.500 Name**
 - C = RO, O = MTA, CN = Ion Bica
- **Subject Alternative Name**
 - Adresa e-mail (rfc822Name)
 - Windows username (UPN)
- **Subject Public Key**
- **Key Usage**
 - digitalSignature (short term signatures)
 - nonRepudiation (long term signatures)
 - keyEncipherment
 - keyAgreement
- **Extended Key Usage**
 - serverAuthentication
 - clientAuthentication
 - codeSigning
 - emailProtection
- **CRL Distribution Points**

Protocoale de autentificare X.509

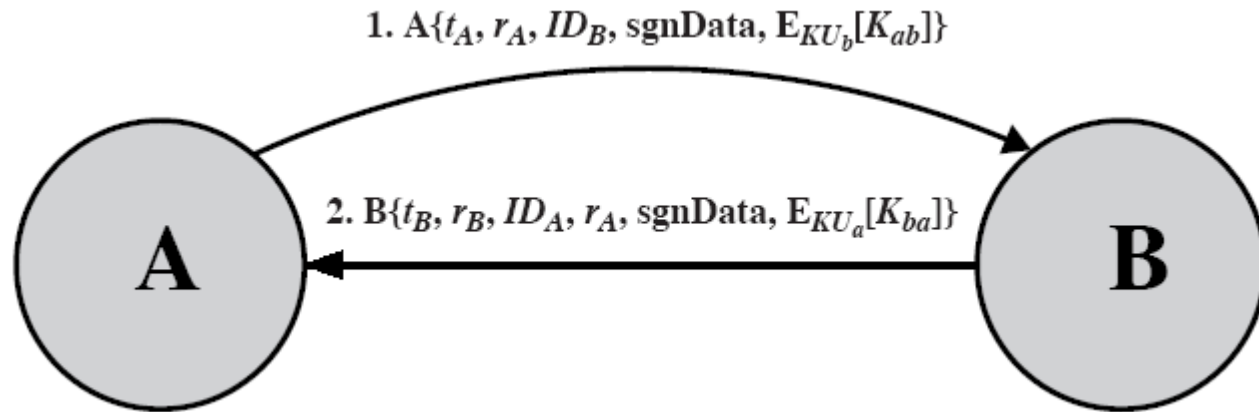
- Autentificarea se realizează făcând dovada posesiei cheii private asociate cheii publice din certificat
 - semnarea digitală a unor date arbitrare
- Certificatul digital în sine nu constituie un factor de autentificare (este public și poate fi obținut de oricine!)
 - certificatul se folosește doar pentru validarea datelor semnate de entitatea ce urmează a fi autentificată
- Protocoale de autentificare X.509
 - One-way authentication
 - Two-way authentication
 - Three-way authentication

One-way authentication



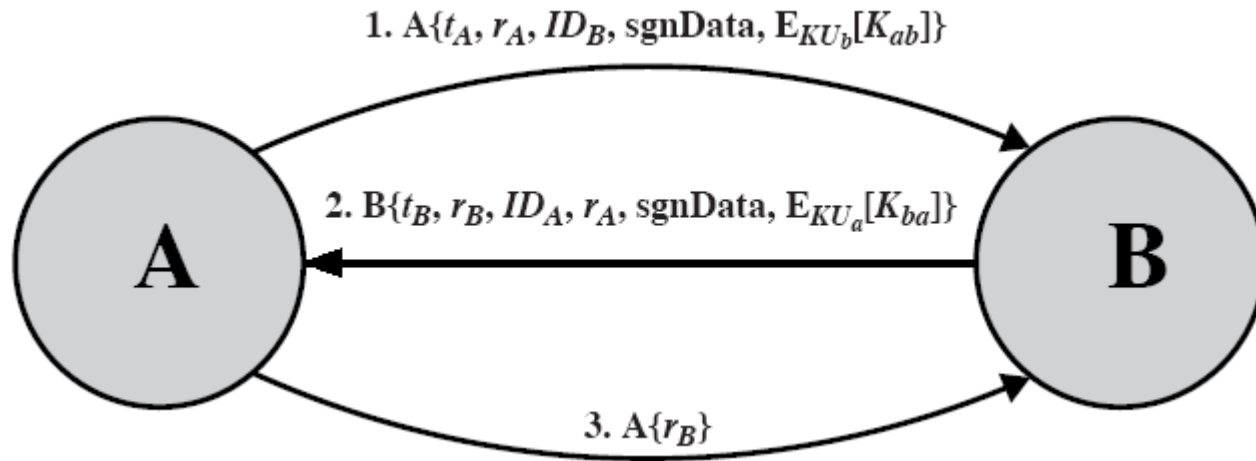
- Un singur schimb de mesaje
- Protocolul asigură:
 - autentificarea lui A la B
 - integritatea și originalitatea datelor (mesajul nu a fost trimis de mai multe ori)

Two-way authentication



- Două schimburi de mesaje
- Protocolul asigură în plus:
 - autentificarea lui B la A
 - integritatea și originalitatea răspunsului

Three-way authentication

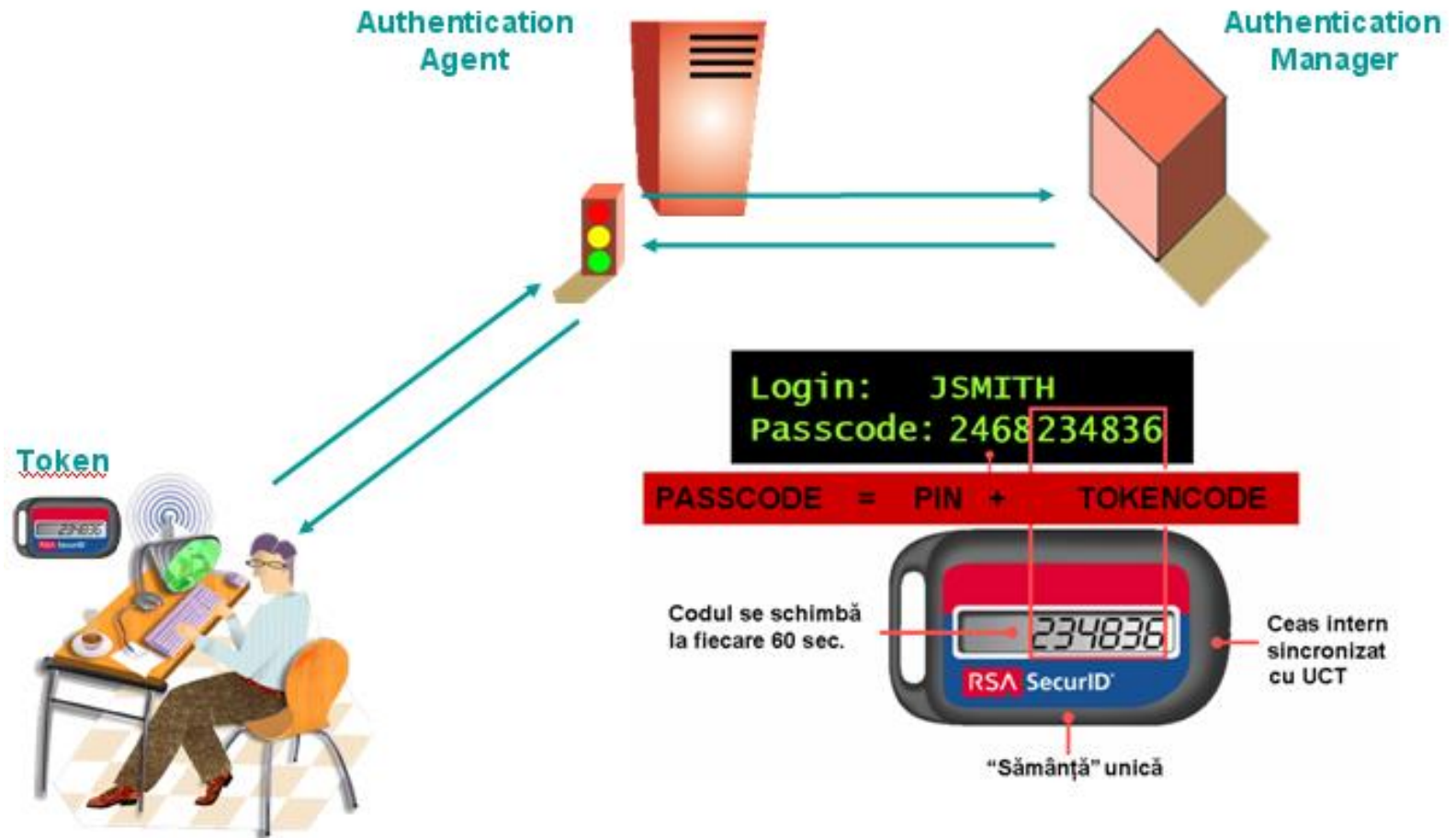


- Trei schimburi de mesaje
- Protocolul asigură în plus:
 - evitarea atacurilor prin reluare în cazul în care ceasurile celor două sisteme nu se pot sincroniza

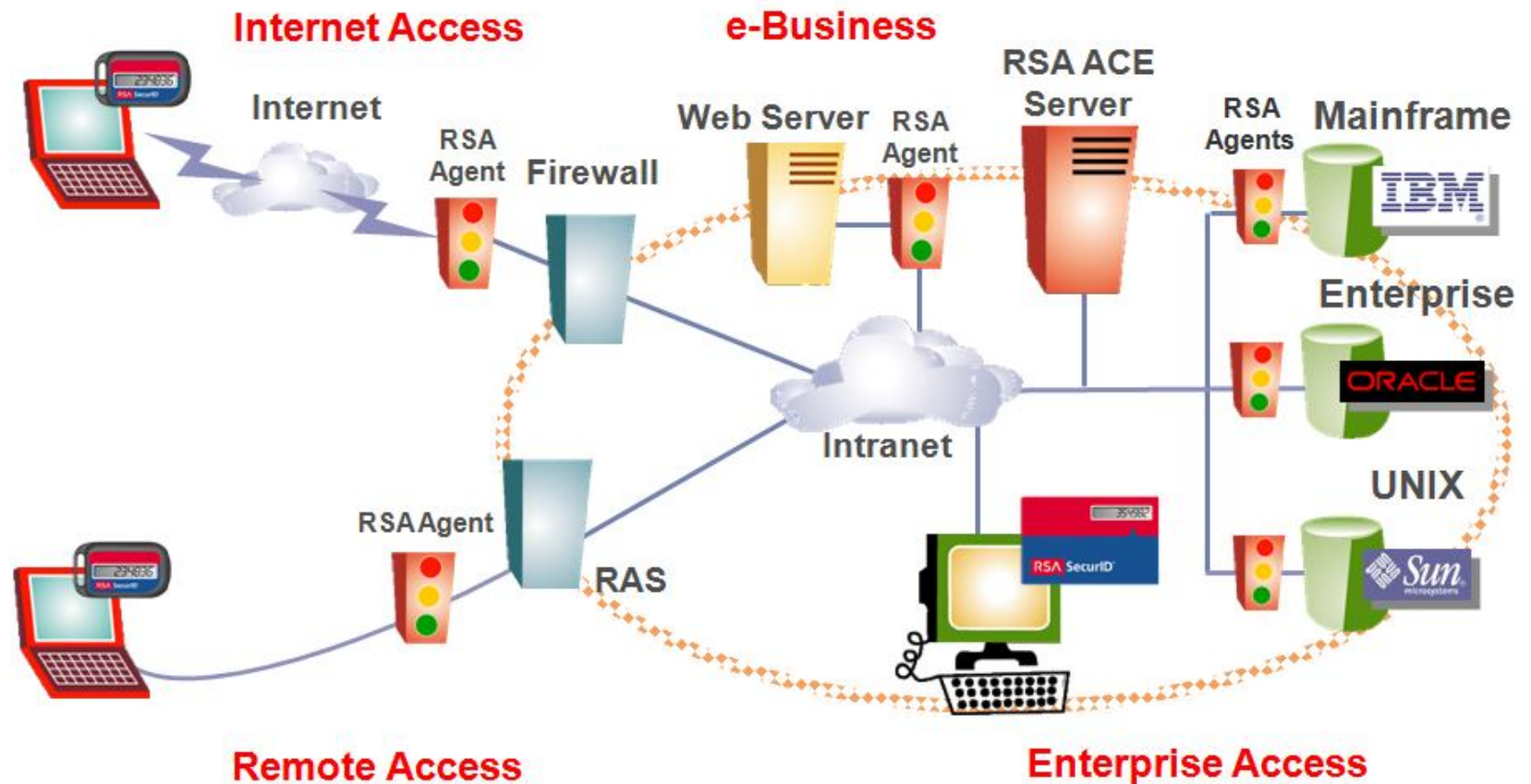
Generatoare de parole de unică folosință

- **Parolele sunt vulnerabile la o serie de atacuri**
 - pot fi interceptate
 - pot fi ghicite sau sparte prin încercări repetate
- **Soluția: parole de unică folosință**
 - nu pot fi refolosite dacă sunt interceptate
 - RSA SecurID
 - VASCO DIGIPASS
 - Gemalto/SafeNet eToken
 - Google Authenticator

RSA SecurID

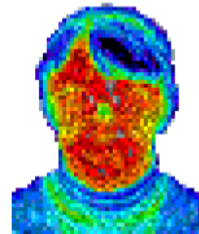
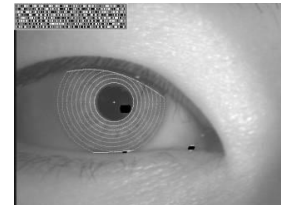
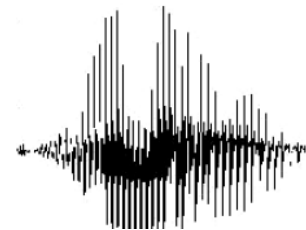


RSA SecurID (cont.)

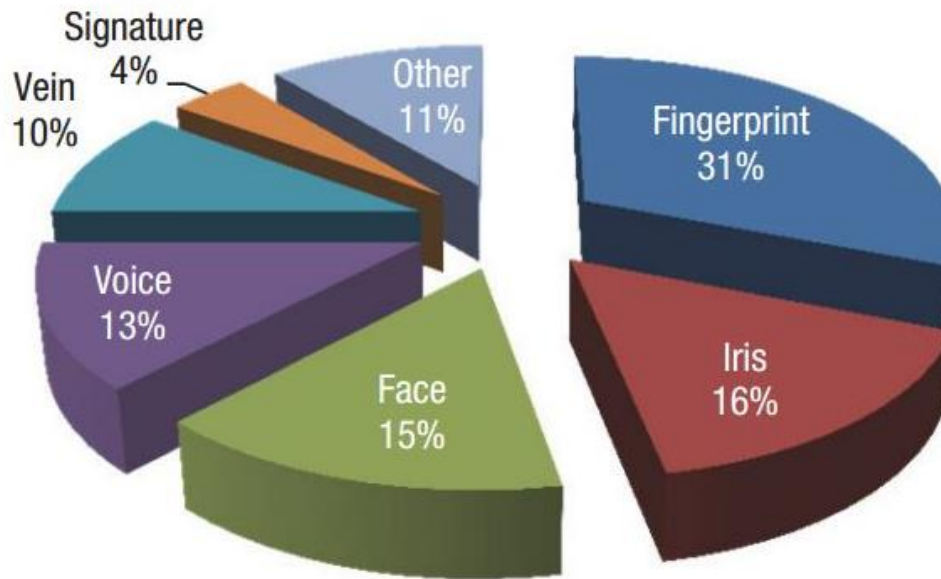


Metode Biometrice

- Amprenta
- Voce
- Iris
- Geometria feței
- Geometria mâinii
- Semnătura olografă
- Scanarea retinei
- Amprenta termică a feței
- ADN
- ...

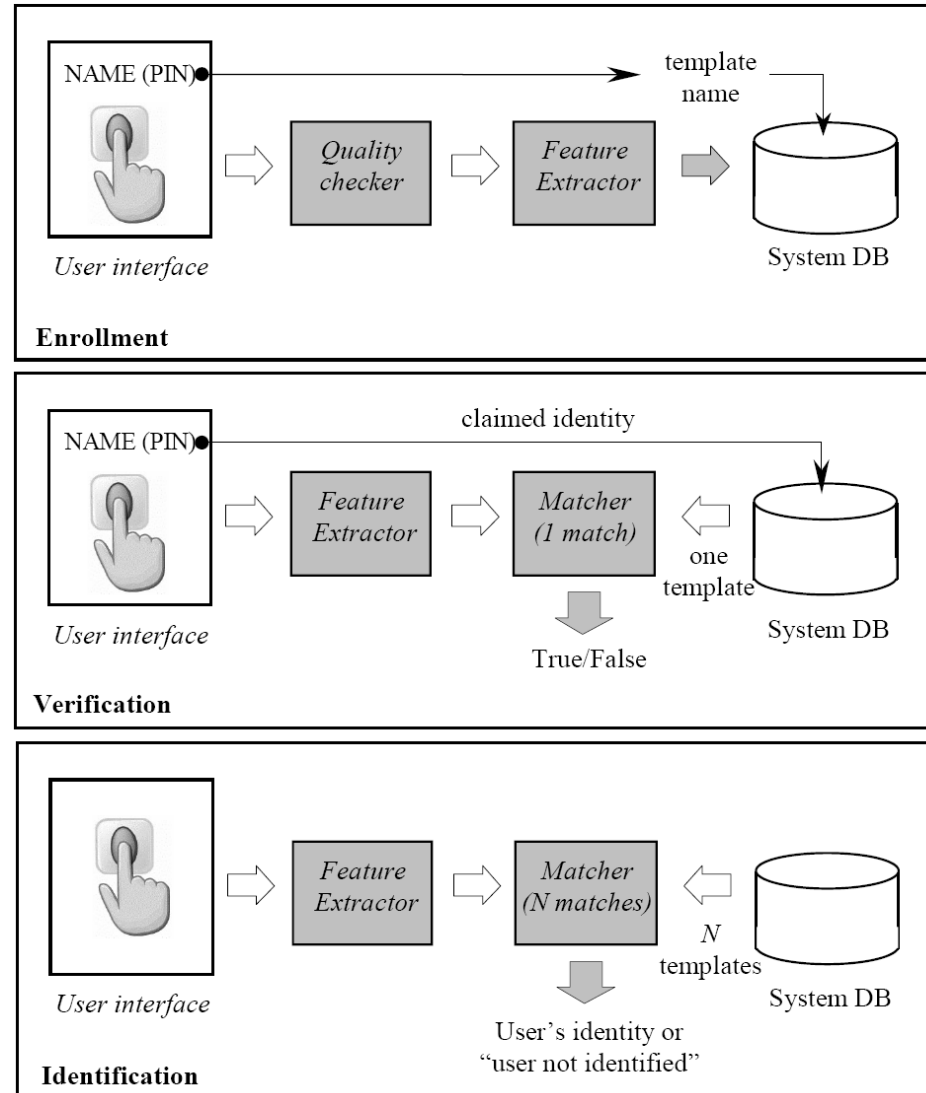


Metode Biometrice (cont.)

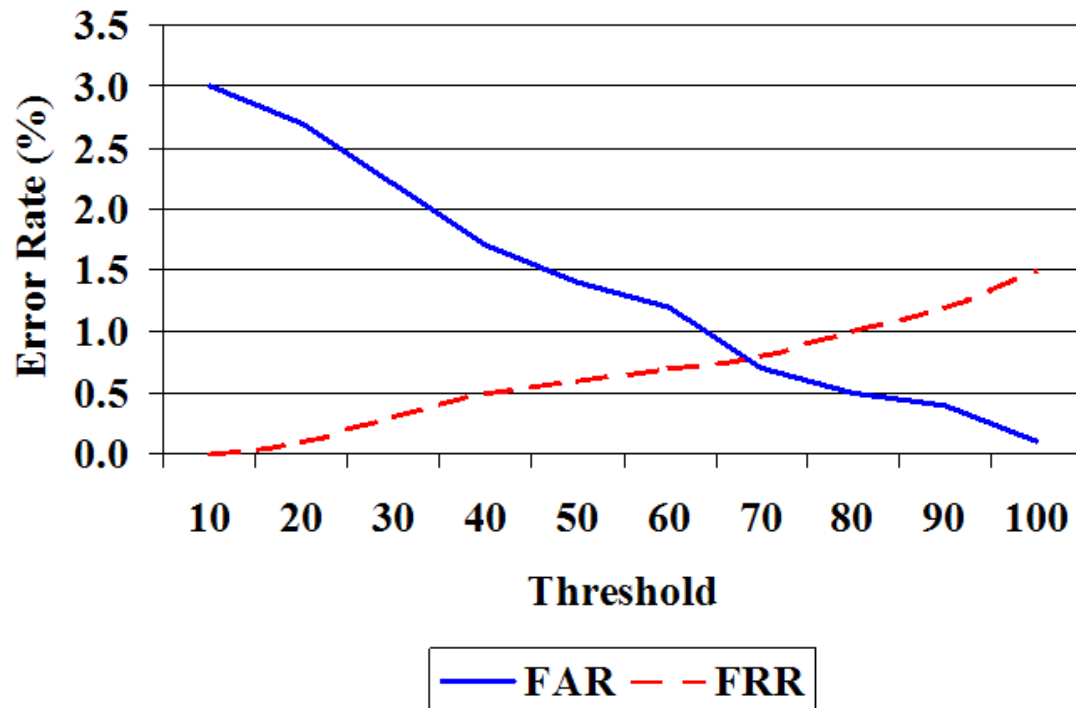


Biometrics market share (2015)

Sistem Biometric



Performanța Sistemelor Biometrice



- False Acceptance Rate (FAR) – Procentul de impostori acceptați în mod greșit de către sistem
- False Rejection Rate (FRR) – Procentul de utilizatori valizi rejectați în mod greșit de către sistem
- Threshold – Valoare ce trebuie setată pentru a controla rata erorilor

Evaluarea Metodelor de Autentificare

Cerințe Organizaționale

- Nivelul de securitate asigurat
- Interoperabilitate
- Robustețe / Scalabilitate
- Flexibilitate

Total Cost of Ownership

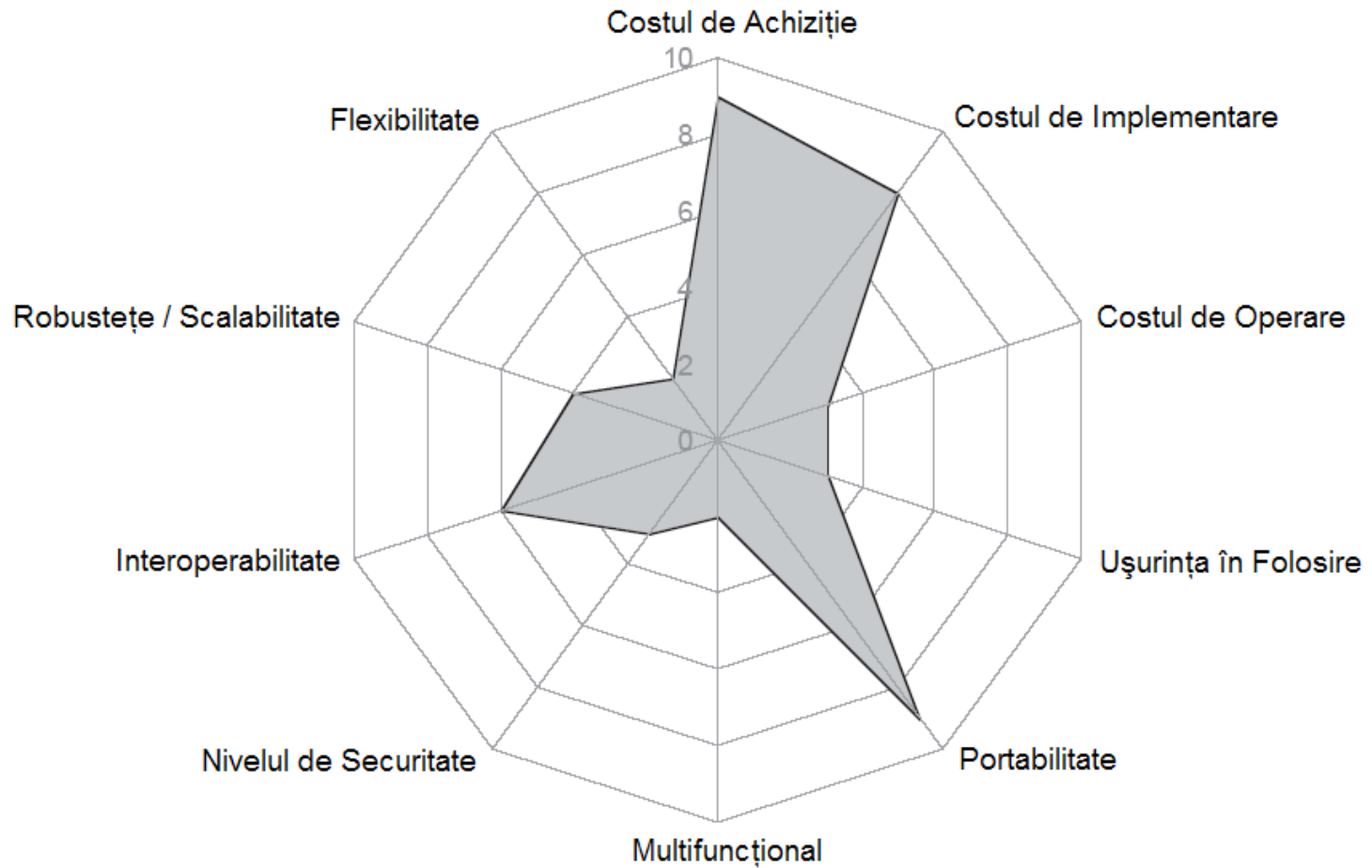
- Costul de achiziție
- Costul de implementare
- Costul de operare

Cerințe Utilizator

- Ușurința în folosire
- Portabilitate
- Multifuncțional

“Există vreo metodă care să satisfacă toate aceste cerințe?”

Parola/PIN



Certificat Digital + Smart Card

